PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Durcissement des systèmes GNU/Linux

03-470 ANSSI - Recommandations de configuration d'un système GNU-Linux — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Les niveaux de durcissement sont gradués en quatre paliers cumulatifs allant du minimal au niveau élevé.
2. Le cloisonnement utilise des techniques comme les espaces de noms, seccomp ou les cgroups pour isoler les processus.
3. Le service auditd permet une journalisation avancée des appels système, des accès fichiers ou des insertions de modules.

Principes et menaces

Notion	À retenir
Niveaux et menaces	**4 niveaux cumulatifs** : **minimal** (systématique), **intermédiaire** (dès que possible), **renforcé** (fort besoin de sécurité), **élevé** (équipes compétentes et disponibles). Menaces : **disponibilité**, **confidentialité**, **intégrité**.
Principes fondamentaux	**Minimisation** (réduit surface d'attaque), **moindre privilège** (limite conséquences vulnérabilité) et **défense en profondeur** (authentification systématique, journalisation centralisée, services avec cloisonnement).

Configuration matérielle et noyau

Notion	À retenir
Matériel et démarrage	Suivre le **guide postes x86**. Configurer/protéger **BIOS/UEFI**, activer **démarrage sécurisé UEFI** (clés remplacées idéalement), mot de passe **chargeur de démarrage**, protéger paramètres **noyau** et **initramfs**.
Configuration noyau	Activer **IOMMU** et **LSM Yama**. Paramétrer options dynamiques (**mémoire**, **noyau**, **processus**, **IPv4**, **systèmes de fichiers**). Désactiver **modules** (niveau renforcé) et **IPv6** (si inutilisé).

Configuration système : partitionnement, accès et maintenance

Notion	À retenir
Partitionnement et comptes	Séparer les zones sensibles, accès restreint à `/boot`. Comptes inutilisés désactivés, mots de passe robustes, sessions expirées. Imputabilité via `sudo` (root verrouillé avec `/bin/false`) ou `auditd` (`execve`, `execveat`). **Un compte système par service** (pas de `nobody` partagé).
Contrôle d'accès obligatoire	Modifier `UMASK`. Utiliser `sudo` (groupe dédié, arguments précis, pas de négations) et **MAC** : `AppArmor` en mode `enforce` ou `SELinux` avec politique `targeted` (outils de débogage désinstallés).
Fichiers, paquets et maintenance	Droits restreints, secrets changés à l'installation. `sticky bit` sur répertoires inscriptibles, éviter `setuid`/`setgid` (surtout root). Paquets strictement nécessaires, dépôts de confiance et mises à jour régulières.

Configuration des services

Notion	À retenir
Cloisonnement système	Appliquer le principe de **minimisation** via **espaces de noms**, `seccomp`, `cgroups`, **conteneurs** ou **hyperviseurs**. Durcir le composant de cloisonnement.
Journalisation et intégrité	`auditd` : appels système, fichiers, modules. Journaux **par service**, accessibles au **seul serveur syslog** (non modifiables par le service). Messagerie locale durcie (alias pour les comptes de service). **Intégrité** des fichiers scellée et vérifiée.
Services réseau	Cloisonner les services, durcir et surveiller les services exposés, et réduire la **surface d'attaque** au strict nécessaire.

Pièges et confusions

- ⚠ Croire que le verrouillage du compte root et la désactivation de son shell empêchent l'usage de sudo bash.
- ⚠ Utiliser le compte générique nobody pour plusieurs services au lieu d'un compte système dédié par service métier.
- ⚠ Oublier que la compromission du noyau ou de l'hyperviseur entraîne la compromission de tous les environnements isolés.
- ⚠ Négliger l'export vers un serveur centralisé lors de la journalisation systématique de la création de processus via auditd.

Sigles et définitions

LSM	Cadre du noyau Linux permettant d'implémenter des mécanismes de contrôle d'accès obligatoire (MAC).
MAC	Contrôle d'accès obligatoire.
DAC	Modèle traditionnel Unix discrétionnaire.
Minimisation	Réduire la surface d'attaque en évitant toute complexité inutile.
Moindre privilège	Tout objet ou entité ne dispose que des droits strictement nécessaires à son exécution.
Défense en profondeur	Plusieurs couches de sécurité indépendantes et complémentaires.
Cloisonnement	Techniques isolant les processus d'un même système.

Auto-test

1. Quels sont les quatre paliers de durcissement ?
2. Quel est l'objectif du principe de minimisation ?
3. Quels sont les deux exemples de mécanismes MAC cités ?
4. Que permet de faire le service auditd ?
5. Quels outils sont utilisés pour le cloisonnement aujourd'hui ?

Réponses : **1.** Minimal, intermédiaire, renforcé et élevé. · **2.** Réduire la surface d'attaque. · **3.** AppArmor ou SELinux. · **4.** Enregistrer des appels système, des accès à des fichiers particuliers ou des insertions de modules. · **5.** Espaces de noms Linux, seccomp et cgroups.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.